

Governance, Regulation, and Case Studies: AI Governance: AI Act (EU), GDPR, OpenAI policy, and global perspectives, Responsible deployment strategies, Case Studies: Microsoft Tay, Meta Galactica, OpenAI ChatGPT, Analysis of mitigation strategies and lessons learned.

What is the EU AI Act?

The AI Act is a European regulation on artificial intelligence (AI) – the first comprehensive regulation on AI by a major regulator anywhere. The Act assigns applications of AI to three risk categories. First, applications and systems that create an **unacceptable risk**, such as government-run social scoring of the type used in China, are banned. Second, **high-risk applications**, such as a CV-scanning tool that ranks job applicants, are subject to specific legal requirements. Lastly, applications not explicitly banned or listed as high-risk are largely left unregulated.

Why should you care?

AI applications influence what information you see online by predicting what content is engaging to you, capture and analyse data from faces to enforce laws or personalise advertisements, and are used to diagnose and treat cancer. In other words, **AI affects many parts of your life.**

Like the EU's General Data Protection Regulation (GDPR) in 2018, the EU AI Act could become a **global standard**, determining to what extent AI has a positive rather than negative effect on your life wherever you may be. The EU's AI regulation is already making waves internationally – in late September 2021, Brazil's Congress passed a bill that creates a legal framework for artificial intelligence.

Who does the EU AI Act apply to?

The EU AI Act applies to multiple operators in the AI value chain, such as providers, deployers, importers, distributors, product manufacturers and authorized representatives). Worthy of mention are the definitions of providers, deployers and importers under the EU AI Act.

Providers

Providers are people or organizations that develop an AI system or general-purpose AI (GPAI) model, or have it developed on their behalf, and who place it on the market or put the AI system into service under their name or trademark.

The act broadly defines an AI system as a system that can, with some level of autonomy, process inputs to infer how to generate outputs (for example, predictions, recommendation, decisions, content) that can influence physical or virtual environments. It defines GPAI as AI models that display significant generality, are capable of competently performing a wide range of distinct tasks, and that can be integrated into a variety of downstream AI systems or applications. For example, a foundation model is a GPAI; a chatbot or generative AI tool built on that model would be an AI system.

Deployers

Deployers are people or organizations that use AI systems. For example, an organization that uses a third-party AI chatbot to handle customer service inquiries would be a deployer.

Importers

Importers are people and organizations located or established in the EU that bring AI systems of a person or company established outside of the EU to the EU market.

Application outside the EU

The EU AI Act also applies to providers and deployers outside of the EU if their AI, or the outputs of the AI, are used in the EU.

For example, suppose a company in the EU sends data to an AI provider outside the EU, who uses AI to process the data, and then sends the output *back* to the company in the EU for use. Because the output of the provider's AI system is used in the EU, the provider is bound by the EU AI Act.

Providers outside the EU that offer AI services in the EU must designate authorized representatives in the EU to coordinate compliance efforts on their behalf.

Exceptions

While the act has a broad reach, some uses of AI are exempt. Purely personal uses of AI, and AI models and systems used only for scientific research and development, are examples of exempt uses of AI.

What requirements does the EU AI Act impose?

The EU AI Act regulates AI systems based on risk level. Risk here refers to the likelihood and severity of the potential harm. Some of the most important provisions include:

- a prohibition on certain AI practices that are deemed to pose unacceptable risk,
- standards for developing and deploying certain high-risk AI systems,
- rules for general-purpose AI (GPAI) models.

AI systems that do not fall within one of the risk categories in the EU AI Act are not subject to requirements under the act (these are often dubbed the ‘minimal risk’ category), although some may need to meet transparency obligations and they must comply with other existing laws. Examples can include email spam filters and video games. Many common AI uses today fall into this category.

It is worth noting that many of the EU AI Act's finer details surrounding implementation are still being ironed out. For example, the act notes that the EU Commission will release further guidance on requirements such as postmarket monitoring plans and training data summaries.

Prohibited AI practices

The EU AI Act explicitly lists certain prohibited AI practices that are deemed to pose an unacceptable level of risk. For example, developing or using an AI system that intentionally manipulates people into making harmful choices they otherwise wouldn't make is deemed by the act to pose unacceptable risk to users, and is a prohibited AI practice.

The EU Commission can amend the list of prohibited practices in the act, so it is possible that more AI practices may be prohibited in the future.

A partial list of Prohibited AI practices at the time this article was published include:

- Social scoring systems—systems that evaluate or classify individuals based on their social behavior—leading to detrimental or unfavorable

treatment in social contexts unrelated to the original data collection and unjustified or disproportionate to the gravity of the behavior

- Emotion recognition systems at work and in educational institutions, except where these tools are used for medical or safety purposes
- AI used to exploit people's vulnerabilities (for example vulnerabilities due to age or disability)
- Untargeted scraping of facial images from the internet or closed-circuit television (CCTV) for facial recognition databases
- Biometric identification systems that identify individuals based on sensitive characteristics
- Specific predictive policing applications
- Law enforcement use of real-time remote biometric identification systems in public (unless an exception applies, and pre-authorization by a judicial or independent administrative authority is generally required).

Standards for high-risk AI

AI systems are considered high-risk under the EU AI Act if they are a product, or safety component of a product, regulated under specific EU laws referenced by the act, such as toy safety and in vitro diagnostic medical device laws.

The act also lists specific uses that are generally considered high-risk, including AI systems used:

- in employment contexts, such as those used to recruit candidates, evaluate applicants and make promotion decisions
- in certain medical devices
- in certain education and vocational training contexts

- in the judicial and democratic process such as systems that are intended to influence the outcome of elections
- to determine access to essential private or public services, including systems that assess eligibility for public benefits and evaluate credit scores.
- in critical infrastructure management (for example, water, gas and electricity supplies and so on)
- in any biometric identification system which are not prohibited, except for systems that whose sole purpose is to verify a person's identity (for example, using a fingerprint scanner to grant someone access to a banking app).

For systems included in this list, an exception may be available if the AI system does not pose a significant threat to health, safety, or rights of individuals. The act specifies criteria, one or more of which must be fulfilled, before an exception can be triggered (for example, where the AI system is intended to perform a narrow procedural task). If relying on this exception, the provider must document its assessment that the system is not high-risk, and regulators can request to see that assessment. The exception is not available for AI systems that automatically process personal data to evaluate or predict some aspect of a person's life, such as their product preferences (profiling), which are always considered high-risk.

As with the list of prohibited AI practices, the EU Commission may update the list of high-risk AI systems in the future.

Requirements for high-risk AI systems

High-risk AI systems must comply with specific requirements. Some examples include:

- Implementing a continuous risk management system to monitor the AI throughout its lifecycle. For example, providers are expected to mitigate reasonably foreseeable risks posed by the intended use of their systems.
- Adopting rigorous data governance practices to ensure that training, validation and testing data meet specific quality criteria. For example, governance around the data collection process and the origin of data, and

measures to prevent and mitigate biases must be in place.

- Maintaining comprehensive technical documentation with specific information including system design specifications, capabilities, limitations, and regulatory compliance efforts.

There are additional transparency obligations for specific types of AI. For example:

- AI systems intended to directly interact with individuals should be designed to inform users that they are interacting with an AI system, unless this is obvious to the individual from the context. A chatbot, for example, should be designed to notify users that it is a chatbot.
- AI systems that generate text, images or other certain other content must use machine-readable formats to mark outputs as AI generated or manipulated. This includes, for example, AI that generates deepfakes—images or video altered to show someone doing or saying something they didn't do or say.

Obligations on operators of high-risk AI systems

We highlight some obligations on key operators of high-risk AI systems in the AI value chain—providers and deployers—below.

Obligations on providers of high-risk AI systems

Providers of high-risk AI systems must comply with requirements including:

- Ensuring high-risk AI systems comply with the requirements for high-risk AI systems outlined in the act. For example, implementing a continuous risk management system.
- Having a quality management system in place.
- Implementing postmarket monitoring plans to monitor the performance of the AI system and evaluate its continued compliance over the system's lifecycle.

Obligations on deployers of high-risk AI systems

Deployers of high-risk AI systems will have obligations including:

- Taking appropriate technical and organizational measures to ensure they use such systems in accordance with their instructions for use.
- Maintaining automatically generated AI system logs, to the extent such logs are under their control, for a specified period.
- For deployers using high-risk AI systems to provide certain essential services—such as government bodies or private organizations providing public services—conducting fundamental rights impact assessments before using certain high-risk AI systems for the first time.

Rules for general purpose AI (GPAI) models

The EU AI Act creates separate rules for general-purpose AI models (GPAI). Providers of GPAI models will have obligations including the following:

- Establishing policies to respect EU copyright laws.
- Writing and making publicly available detailed summaries of training data sets.

If a GPAI model is classified as posing a systemic risk, providers will have additional obligations. Systemic risk is a risk specific to the high-impact capabilities of GPAI models that have a significant impact on the EU market due to their reach or due to actual or reasonably foreseeable negative effects on public health, safety, public security, fundamental rights or the society as a

whole, that can be propagated at scale across the value chain. The act uses training resources as one of the criteria for identifying systemic risk—if the cumulative amount of computing power used to train a model is greater than 10^{25} floating point operations (FLOPs), it is presumed to have high-impact capabilities and pose a systemic risk. The EU Commission can also classify a model as posing a systemic risk.

Providers of GPAI models that pose a systemic risk, including free, open-source models, must meet some additional obligations, for example:

- Documenting and reporting serious incidents to the EU AI Office and relevant national regulators.
- Implementing adequate cybersecurity to protect the model and its physical infrastructure.

EU AI Act fines

For noncompliance with the prohibited AI practices organizations can be fined up to EUR 35,000,000 or 7% of worldwide annual turnover, whichever is higher.

For most other violations, including noncompliance with the requirements for high-risk AI systems, organizations can be fined up to EUR 15,000,000 or 3% of worldwide annual turnover, whichever is higher.

The supply of incorrect, incomplete or misleading information to authorities can result in organizations being fined up to EUR 7,500,000 or 1% of worldwide annual turnover, whichever is higher.

Notably, the EU AI Act has different rules for fining start-ups and other small and medium-size organizations. For these businesses, the fine is the *lower* of the two possible amounts specified above.

When does the EU AI Act take effect?

The law entered into force on 1 August 2024, with different provisions of the law going into effect in stages. Some of the most notable dates include:

- From 2 February 2025 the prohibitions on prohibited AI practices will take effect.
- From 2 August 2025, the rules for general-purpose AI will take effect for new GPAI models. Providers of GPAI models that were placed on the market before 2 August 2025 will have until 2 August 2027 to comply.
- From 2 August 2026, the rules for high-risk AI systems will take effect.
- From 2 August 2027, the rules for AI systems that are products or safety components of products regulated under specific EU laws, will apply.

On 13 March 2024, the European Parliament plenary session formally adopted at first reading the EU AI Act. The EU AI Act is now expected to be formally

adopted in a few weeks' time. Following publication in the Official Journal of the European Union, it will enter into force 20 days later.

Artificial intelligence (“**AI**”) systems rely on data inputs from initial development, through the training phase, and in live use. Given the broad definition of personal data under European data protection laws, AI systems' development and use will frequently result in the processing of personal data.

At its heart, the EU AI Act is a product safety law that provides for the safe technical development and use of AI systems. With a couple of exceptions, it does not create any rights for individuals. By contrast, the GDPR is a fundamental rights law that gives individuals a wide range of rights in relation to the processing of their data. As such, the EU AI Act and the GDPR are designed to work hand-in-glove, with the latter ‘filling the gap’ in terms of individual rights for scenarios where AI systems use data relating to living persons.

Consequently, as AI becomes a regulated technology through the EU AI Act, practitioners and organisations must understand the close relationship between the EU data protection law and the EU AI Act.

1. EU data protection law and AI systems

1.1 The GDPR and AI systems

- The General Data Protection Regulation (“**GDPR**”) is a technology-neutral regulation. As the definition of “*processing*” under the GDPR is broad (and in practice includes nearly all activities conducted on personal data, including data storage), it is evident that the GDPR applies to AI systems, to the extent that personal data is present somewhere in the lifecycle of an AI system.
- It is often technically very difficult to separate personal data from non-personal data, which increases the likelihood that AI systems process personal data at some point within their lifecycle.
- While AI is not explicitly mentioned in the GDPR, the automated decision-making framework (article 22 GDPR) serves as a form of indirect control over the use of AI systems, on the basis that AI systems are frequently used to take automated decisions that impact individuals.
- In some respects, there is tension between the GDPR and AI. AI typically entails the collection of vast amounts of data (in particular, in the training phase), while many AI systems have a broad potential range of applications

(reflecting the imitation of human-like intelligence), making the clear definition of “processing purposes” difficult.

- At the same time, there is a clear overlap between many of the data protection principles and the principles and requirements established by the EU AI Act for the safe development and use of AI systems. The relationship between AI and data protection is expressly recognised in the text of the EU AI Act, which states that it is without prejudice to the GDPR. In developing the EU AI Act, the European Commission relied in part on article 16 of the Treaty on the Functioning of the European Union (“TFEU”), which mandates the EU to lay down the rules relating to the protection of individuals regarding the processing of personal data.

1.2 Data protection authorities’ enforcement against AI systems

- Before the EU AI Act, the EU data protection authorities (“DPA”) were among the first regulatory bodies to take enforcement action against the use of AI systems. These enforcement actions have been based on a range of concerns, in particular, lack of legal basis to process personal data or special categories of personal data, lack of transparency, automated decision-making abuses, failure to fulfil data subject rights and data accuracy issues.
- Examples of DPA enforcement actions are already lengthy. The most notable ones include the Italian DPA’s temporary ban decision on OpenAI’s ChatGPT, the Italian DPA’s Deliveroo fine in relation to the company’s AI-enabled automated rating of rider performance, the French DPA’s Clearview AI fine, a facial recognition platform that scrapes billions of photographs from the internet and the Dutch DPA’s fine on the Dutch Tax and Customs Administration for various GDPR infringements in relation to an AI-based fraud notification facility application.
- As the DPAs shape their enforcement policies based in part on public concerns, and as public awareness of and interest in AI continues to rise, it is likely that DPAs will continue to sharpen their focus on AI (also *see* section 6 for DPAs as a potential enforcer of the EU AI Act).

2. Scope and applicability of the GDPR and EU AI Act

2.1 Scope of the GDPR and the EU AI Act

- The material scope of the GDPR is the processing of personal data by wholly or partly automated means, or manual processing of personal data where that data forms part of a relevant filing system (article 2 GDPR).

The territorial scope of the GDPR is defined in article 3 GDPR and covers different scenarios.

- Consequently, the GDPR has an extraterritorial scope, meaning that: Controllers and processors established in the EU processing in the context of that establishment must comply with the GDPR even if the processing of personal data occurs in a third country. Non-EU controllers and processors have to comply with the GDPR if they target or monitor individuals in the EU.
- On the other hand, the material scope of the EU AI Act is based around its definition of an AI system. Territorially, the EU AI Act applies to providers, deployers, importers, distributors, and authorised representatives (*see*, section 2.2 for details).
- Unlike the GDPR, the EU AI Act has a robust risk categorisation, and it brings different obligations to the different AI risk categories. Most obligations under the EU AI Act apply to high-risk AI systems only (covered in article 6 and Annex III EU AI Act). Various AI systems are also subject to specific obligations (such as general-purpose AI models) and transparency obligations (such as emotional categorisation systems).

2.2 Interplay between roles under the GDPR and the EU AI Act

- As the GDPR distinguishes between controllers and processors, so the EU AI Act distinguishes between different categories of regulated operators.
- The provider (the operator who develops an AI system or has an AI system developed) and the deployer (the operator under whose authority an AI system is used) are the most significant in practice.
- Organisations that process personal data in the course of developing or using an AI system will need to consider the roles they play under both the GDPR and the EU AI Act. Some examples follow.

Example 1: provider (the EU AI Act) and controller (the GDPR)	Example 2: deployer (EU AI Act) and controller (the GDPR)
A company (A) that processes personal data in the context of training a new AI system will be acting as both a provider under the EU AI Act and as a controller under the GDPR. This is because the	A company (B) that purchases the AI system described in Example 1: provider (EU AI Act) and controller (the GDPR) from company A and uses it in a way that involves the processing of personal data (for

company is developing a new AI system and, as part of that development, is taking decisions about how to process personal data for the purpose of training the AI system.	example, as a chatbot to talk to customers, or as an automated recruitment tool) will be acting as both a deployer under the EU AI Act and as a separate controller under the GDPR for the processing of its own personal data (that is, it is not the controller for the personal data used to originally train the AI system but it is for any data it uses in conjunction with the AI).
---	--

- More complex scenarios may arise when companies offer services that involve the processing of personal data and the use of an AI system to process that data. Depending on the facts, the customers of such services may qualify as controllers or processors (under the GDPR) although they would typically be deployers under the EU AI Act.
- These examples raise important questions about the relationship between the nature of roles under the EU AI Act and their relationship to roles under the GDPR which are still to be resolved in practice. Companies that develop or deploy AI systems should carefully analyse their roles under the respective laws, preferably prior to the kick-off of relevant development and deployment projects.

3. Relationship between the GDPR principles and the EU AI Act

- The GDPR is built around the data protection principles set out in article 5 GDPR. These principles are lawfulness, fairness, transparency, purpose limitation, data minimisation, accuracy, storage limitation, integrity and confidentiality.
- On the other hand, the first intergovernmental standard on AI, the recommendation on artificial intelligence issued by the OECD (OECD Recommendation of the Council on Artificial Intelligence, “**OECD AI Principles**”) introduces five complementary principles for responsible stewardship of trustworthy AI that have strong links to the principles in the GDPR: Inclusive growth, sustainability and well-being, human centred-values, fairness, transparency, explainability, robustness, security, safety and accountability.

- The EU AI Act also refers to general principles applicable to all AI systems, as well as specific obligations that require the principles to be put in place in certain methods. The EU AI Act principles are set out in recital 27 and are influenced by the OECD AI Principles and the seven ethical principles for AI developed by the independent High-Level Expert Group on AI (HLEG). Although recitals do not have the same legally binding status as the operative provisions which follow them and cannot overrule an operative provision, they can help with interpretation and to determine meaning.
- Recital 27 EU AI Act refers to the following principles: Human agency and oversight, technical robustness and safety, privacy and data governance, transparency, diversity, non-discrimination, fairness, social and environmental wellbeing. Some of these principles already materialise through specific EU AI Act obligations: Article 10 EU AI Act prescribes data governance practices for high-risk AI systems, article 13 EU AI Act deals with transparency, articles 14 and 26 EU AI Act introduce human oversight and monitoring requirements, article 27 EU AI Act introduces the obligation to conduct fundamental rights impact assessments for some high-risk AI systems.
- Understanding the synergies and differences between the GDPR principles and the EU AI Act principles will allow organisations to leverage their existing knowledge of GDPR and their existing GDPR compliance programmes. This is therefore a crucial step to lower compliance costs. The full practice note includes comprehensive tables that compare the practicalities in this regard.

4. Human oversight under the EU AI Act and automated decision-making under the GDPR

- Under article 22 GDPR, data subjects have the right not to be subject to solely automated decisions involving the processing of personal data that result in legal or similarly significant effects. Where such decisions are taken, they must be based on one of the grounds set out in article 22(2) GDPR.
- Like the GDPR, the EU AI Act is also concerned with ensuring that fundamental rights and freedoms are protected by allowing for appropriate human supervision and intervention (the so called “human-in-the-loop” effect).
- Article 14 EU AI Act requires high-risk AI system to be designed and developed in such a way (including with appropriate human-machine interface tools) that they can be effectively overseen by natural persons

during the period in which the AI system is in use. In other words, providers must take a “human-oversight-by-design” approach to developing AI systems.

- According to article 26.1 EU AI Act, the deployer of an AI system must take appropriate technical and organisational measures to ensure its use of an AI system is in accordance with the instructions of use accompanying the system, including with respect to human oversight.
- The level of human oversight and intervention exercised by a user of an AI system may be determinative in bringing the system in or out of scope of the automated decision-making framework under the GDPR. In other words, a meaningful intervention by a human being at a key stage of the AI system’s decision-making process may be sufficient to ensure that the decision is no longer wholly automated for the purposes of article 22 GDPR. Perhaps more likely, AI systems will be used to make wholly automated decisions, but effective human oversight will operate as a safeguard to ensure that the automated decision-making process is fair and that an individual’s rights, including their data protection rights, are upheld.

5. Conformity assessments and fundamental rights impact assessments under the EU AI Act and the DPIAs under the GDPR

- Under the EU AI Act, the conformity assessment is designed to ensure accountability by the provider with each of the EU AI Act’s requirements for the safe development of a high-risk AI system (as set out in Title III, Chapter 2 EU AI Act). Conformity assessments are not risk assessments but rather demonstrative tools that show compliance with the EU AI Act’s requirements.
- The DPIA, on the other hand, is a mandatory step required under the GDPR for high-risk personal data processing activities.
- Consequently, there are significant differences in terms of both purpose and form between a conformity assessment and a DPIA. However, in the context of high-risk AI systems, the provider of such systems may also need to conduct a DPIA relation to the use of personal data in the development and training of the system. In such case, the technical documentation that are drafted for conformity assessments may help establishing the factual context of a DPIA. Similarly, the technical information may be helpful to a deployer of the AI system that is required to conduct a DPIA in relation to its use of the system.
- The requirement under the EU AI Act to conduct a fundamental rights impact assessment (“**FRIA**”) is similar, conceptually, to a DPIA. As with a DPIA, the purpose of a FRIA is to identify and mitigate risks to the

fundamental rights of natural persons, in this case arising from the deployment of an AI system. For more details regarding the FRIA, see *Fundamental Rights Impact Assessments under the EU AI Act: Who, what and how?*.

- Practically speaking, organisations generally already have governance mechanisms in place to bring legal, IT and business professionals together for impact assessments such as the DPIA. When it comes to a FRIA, such mechanisms can be leveraged. As with a DPIA, the first step is likely to consist of a pre-FRIA screening to identify the use of an in-scope high-risk AI system (recognising that, as a good practice step, organisations may choose to conduct FRIAs for a wider range of AI systems than is strictly required by the EU AI Act).

6. National competent authorities under EU AI Act and DPAs

- Under the EU AI Act, each member state is required to designate one or more national competent authorities to supervise the application and implementation of the EU AI Act, as well as to carry out market surveillance activities.
- The national competent authorities will be supported by the European Artificial Intelligence Board and the European AI Office. The most notable duty of the European AI Office is to enforce and supervise the new rules for general purpose AI models.
- The appointment of the DPAs as enforcers of the EU AI Act will solidify the close relationship between the EU GDPR and the EU AI Act.

Open AI's Policy

Terms & policies

Universal policies

To maximize innovation and creativity, we believe you should have the flexibility to use our services as you see fit, so long as you comply with the law and don't harm yourself or others. When using any OpenAI service, like ChatGPT, labs.openai.com, and the OpenAI API, these rules apply:

Comply with applicable laws—for example, do not: Compromise the privacy of others

Engage in regulated activity without complying with applicable regulations

Promote or engage in any illegal activity, including the exploitation or harm of children and the development or distribution of illegal substances, goods, or services

Use subliminal, manipulative, or deceptive techniques that distort a person's behavior so that they are unable to make informed decisions in a way that is likely to cause harm

Exploit any vulnerabilities related to age, disability, or socio-economic circumstances

Create or expand facial recognition databases without consent

Conduct real-time remote biometric identification in public spaces for law enforcement purposes

Evaluate or classify individuals based on their social behavior or personal traits (including social scoring or predictive profiling) leading to detrimental or unfavorable treatment

Assess or predict the risk of an individual committing a criminal offense based solely on their personal traits or on profiling

Infer an individual's emotions in the workplace and educational settings, except when necessary for medical or safety reasons

Categorize individuals based on their biometric data to deduce or infer sensitive attributes such as their race, political opinions, religious beliefs, or sexual orientation.

Don't use our service to harm yourself or others—for example, don't use our services to promote suicide or self-harm, develop or use weapons, injure others or destroy property, or engage in unauthorized activities that violate the security of any service or system.

Don't repurpose or distribute output from our services to harm others—for example, don't share output from our services to defraud, scam, spam, mislead, bully, harass, defame, discriminate based on protected attributes, sexualize children, or promote violence, hatred or the suffering of others.

Respect our safeguards—don't circumvent safeguards or safety mitigations in our services unless supported by OpenAI (e.g., domain experts in our Red

Teaming Network) or related to research conducted in accordance with our Sharing & Publication Policy.

We report apparent child sexual abuse material (CSAM) to the National Center for Missing and Exploited Children.

Building with the OpenAI API Platform

The OpenAI Platform allows you to build entirely custom applications. As the developer of your application, you are responsible for designing and implementing how your users interact with our technology. To make this easier, we've shared our Safety best practices([opens in a new window](#)), and offer tools like our Moderation Endpoint([opens in a new window](#)) and customizable system messages.

We recognize that our API introduces new capabilities with scalable impact, so we have service-specific policies that apply to all use of our APIs in addition to our Universal Policies:

Don't compromise the privacy of others, including:

Collecting, processing, disclosing, inferring or generating personal data without complying with applicable legal requirements

Using biometric systems for identification or assessment, including facial recognition

Facilitating spyware, communications surveillance, or unauthorized monitoring of individuals

Don't perform or facilitate the following activities that may significantly impair the safety, wellbeing, or rights of others, including:

Providing tailored legal, medical/health, or financial advice without review by a qualified professional and disclosure of the use of AI assistance and its potential limitations

Making high-stakes automated decisions in domains that affect an individual's safety, rights or well-being (e.g., law enforcement, migration, management of critical infrastructure, safety components of products, essential services, credit, employment, housing, education, social scoring, or insurance)

Facilitating real money gambling or payday lending

Engaging in political campaigning or lobbying, including generating campaign materials personalized to or targeted at specific demographics

Deterring people from participation in democratic processes, including misrepresenting voting processes or qualifications and discouraging voting

Don't misuse our platform to cause harm by intentionally deceiving or misleading others, including

Generating or promoting disinformation, misinformation, or false online engagement (e.g., comments, reviews)

Impersonating another individual or organization without consent or legal right

Engaging in or promoting academic dishonesty

Failing to ensure that automated systems (e.g., chatbots) disclose to people that they are interacting with AI, unless it's obvious from the context

Don't build tools that may be inappropriate for minors, including:

Sexually explicit or suggestive content. This does not include content created for scientific or educational purposes.

Building with ChatGPT

Shared GPTs allow you to use ChatGPT to build experiences for others. Because your GPT's users are also OpenAI users, when building with ChatGPT, we have the following service-specific policies in addition to our Universal Policies:

Don't compromise the privacy of others, including:

Collecting, processing, disclosing, inferring or generating personal data without complying with applicable legal requirements

Soliciting or collecting the following sensitive identifiers, security information, or their equivalents: payment card information (e.g. credit card numbers or bank account information), government identifiers (e.g. SSNs), API keys, or passwords

Using biometric identification systems for identification or assessment, including facial recognition

Facilitating spyware, communications surveillance, or unauthorized monitoring of individuals

Don't perform or facilitate the following activities that may significantly affect the safety, wellbeing, or rights of others, including:

Taking unauthorized actions on behalf of users

Providing tailored legal, medical/health, or financial advice

Making automated decisions in domains that affect an individual's rights or well-being (e.g., law enforcement, migration, management of critical infrastructure, safety components of products, essential services, credit, employment, housing, education, social scoring, or insurance)

Facilitating real money gambling or payday lending

Engaging in political campaigning or lobbying, including generating campaign materials personalized to or targeted at specific demographics

Deterring people from participation in democratic processes, including misrepresenting voting processes or qualifications and discouraging voting

Don't misinform, misrepresent, or mislead others, including:

Generating or promoting disinformation, misinformation, or false online engagement (e.g., comments, reviews)

Impersonating another individual or organization without consent or legal right

Engaging in or promoting academic dishonesty

Using content from third parties without the necessary permissions

Misrepresenting or misleading others about the purpose of your GPT

Don't build tools that may be inappropriate for minors, including:

Sexually explicit or suggestive content. This does not include content created for scientific or educational purposes.

Don't build tools that target users under 13 years of age.

We use a combination of automated systems, human review, and user reports to find and assess GPTs that potentially violate our policies. Violations can lead to

actions against the content or your account, such as warnings, sharing restrictions, or ineligibility for inclusion in GPT Store or monetization.

GPT store

We want to make sure that GPTs in the GPT Store are appropriate for all users. For example, GPTs that contain profanity in their names or that depict or promote graphic violence are not allowed in our Store. We also don't allow GPTs dedicated to fostering romantic companionship or performing regulated activities.

These policies may be enforced automatically at submission time or applied retroactively upon further review.

Privacy Policy

1. Personal Data we collect

We collect personal data relating to you ("Personal Data") as follows:

Personal Data You Provide: We collect Personal Data if you create an account to use our Services or communicate with us as follows:

Account Information: When you create an account with us, we will collect information associated with your account, including your name, contact information, account credentials, date of birth, payment information, and transaction history, (collectively, "Account Information").

User Content: We collect Personal Data that you provide in the input to our Services ("Content"), including your prompts and other content you upload, such as files([opens in a new window](#)), images([opens in a new window](#)), and audio([opens in a new window](#)), depending on the features you use.

Communication Information: If you communicate with us, such as via email or our pages on social media sites, we may collect Personal Data like your name, contact information, and the contents of the messages you send ("Communication Information").

Other Information You Provide: We collect other information that you may provide to us, such as when you participate in our events or surveys or provide

us with information to establish your identity or age (collectively, “Other Information You Provide”).

Personal Data We Receive from Your Use of the Services: When you visit, use, or interact with the Services, we receive the following information about your visit, use, or interactions (“Technical Information”):

Log Data: We collect information that your browser or device automatically sends when you use our Services. Log data includes your Internet Protocol address, browser type and settings, the date and time of your request, and how you interact with our Services.

Usage Data: We collect information about your use of the Services, such as the types of content that you view or engage with, the features you use and the actions you take, as well as your time zone, country, the dates and times of access, user agent and version, type of computer or mobile device, and your computer connection.

Device Information: We collect information about the device you use to access the Services, such as the name of the device, operating system, device identifiers, and browser you are using. Information collected may depend on the type of device you use and its settings.

Location Information: We may determine the general area from which your device accesses our Services based on information like its IP address for security reasons and to make your product experience better, for example to protect your account by detecting unusual login activity or to provide more accurate responses. In addition, some of our Services allow you to choose to provide more precise location information from your device, such as location information from your device’s GPS.

Cookies and Similar Technologies: We use cookies and similar technologies to operate and administer our Services, and improve your experience. If you use our Services without creating an account, we may store some of the information described in this policy with cookies, for example to help maintain your preferences across browsing sessions. For details about our use of cookies, please read our Cookie Notice.

Information We Receive from Other Sources: We receive information from our trusted partners, such as security partners, to protect against fraud, abuse,

and other security threats to our Services, and from marketing vendors who provide us with information about potential customers of our business services.

We also collect information from other sources, like information that is publicly available on the internet, to develop the models that power our Services. For more information on the sources of information used to develop the models that power ChatGPT and other Services, please see this [article](#).

2. How we use Personal Data

We may use Personal Data for the following purposes:

To provide, analyze, and maintain our Services, for example to respond to your questions for ChatGPT;

To improve and develop our Services and conduct research, for example to develop new product features;

To communicate with you, including to send you information about our Services and events, for example about changes or improvements to the Services;

To prevent fraud, illegal activity, or misuses of our Services, and to protect the security of our systems and Services;

To comply with legal obligations and to protect the rights, privacy, safety, or property of our users, OpenAI, or third parties.

We may also aggregate or de-identify Personal Data so that it no longer identifies you and use this information for the purposes described above, such as to analyze the way our Services are being used, to improve and add features to them, and to conduct research. We will maintain and use de-identified information in de-identified form and not attempt to reidentify the information, unless required by law.

As noted above, we may use Content you provide us to improve our Services, for example to train the models that power ChatGPT. Read our [instructions](#) (opens in a new window) on how you can opt out of our use of your Content to train our models.

3. Disclosure of Personal Data

We may disclose your Personal Data in the following circumstances:

Vendors and Service Providers: To assist us in meeting business operations needs and to perform certain services and functions, we may disclose Personal Data to vendors and service providers, including providers of hosting services, customer service vendors, cloud services, content delivery services, support and safety monitoring services, email communication software, web analytics services, payment and transaction processors, and other information technology providers. Pursuant to our instructions, these parties will access, process, or store Personal Data only in the course of performing their duties to us.

Business Transfers: If we are involved in strategic transactions, reorganization, bankruptcy, receivership, or transition of service to another provider (collectively, a “Transaction”), your Personal Data may be disclosed in the diligence process with counterparties and others assisting with the Transaction and transferred to a successor or affiliate as part of that Transaction along with other assets.

Government Authorities or Other Third Parties: We may share your Personal Data, including information about your interaction with our Services, with government authorities, industry peers, or other third parties in compliance with the law (i) if required to do so to comply with a legal obligation, or in the good faith belief that such action is necessary to comply with a legal obligation, (ii) to protect and defend our rights or property, (iii) if we determine, in our sole discretion, that there is a violation of our terms, policies, or the law; (iv) to detect or prevent fraud or other illegal activity; (v) to protect the safety, security, and integrity of our products, employees, users, or the public, or (vi) to protect against legal liability.

Affiliates: We may disclose Personal Data to our affiliates, meaning an entity that controls, is controlled by, or is under common control with OpenAI. Our affiliates may use this Personal Data in a manner consistent with this Privacy Policy.

Business Account Administrators: When you join a ChatGPT Enterprise or business account, the administrators of that account may access and control your OpenAI account, including being able to access your Content. In addition, if you create an account using an email address belonging to your employer or

another organization, we may share the fact that you have an account and certain account information, such as your email address, with your employer or organization to, for example, enable you to be added to their business account.

Other Users and Third Parties You Interact or Share Information With:

Certain features allow you to interact or share information with other users or third parties. For example, you can share ChatGPT conversations with other users via shared links([opens in a new window](#)). You can also send information to third-party applications, such as via custom actions for GPTs, or for searching the web to help answer questions that benefit from more recent information. Information you share with third parties is governed by their own terms and privacy policies, and you should make sure you understand those terms and policies before sharing information with them.

4. Retention

We'll retain your Personal Data for only as long as we need in order to provide our Services to you, or for other legitimate business purposes such as resolving disputes, safety and security reasons, or complying with our legal obligations. How long we retain Personal Data will depend on a number of factors, such as:

Our purpose for processing the data (such as whether we need to retain the data to provide our Services);

The amount, nature, and sensitivity of the information;

The potential risk of harm from unauthorized use or disclosure;

Any legal requirements that we are subject to.

In some cases, the length of time we retain data depends on your settings. For example, ChatGPT temporary chats will not appear in your history and will be kept up to 30 days for safety purposes. You can find more information on data controls [here](#)([opens in a new window](#)).

5. Your rights

Depending on where you live, you may have certain statutory rights in relation to your Personal Data. For example, you may have the right to:

Access your Personal Data and information relating to how it is processed.

Delete your Personal Data from our records.

Update or correct your Personal Data.

Transfer your Personal Data to a third party (right to data portability).

Restrict how we process your Personal Data.

Withdraw your consent—where we rely on consent as the legal basis for processing at any time.

Object to how we process your Personal Data.

Lodge a complaint with your local data protection authority.

You can exercise some of these rights through your OpenAI account. If you are unable to exercise your rights through your account, please submit your request through privacy.openai.com(opens in a new window) or to dsar@openai.com. You can contact our data protection officer at privacy@openai.com.

A note about accuracy: Services like ChatGPT generate responses by reading a user's request and, in response, predicting the words most likely to appear next. In some cases, the words most likely to appear next may not be the most factually accurate. For this reason, you should not rely on the factual accuracy of output from our models. If you notice that ChatGPT output contains factually inaccurate information about you and you would like to request a correction or removal of the information, you can submit these requests through privacy.openai.com(opens in a new window) or to dsar@openai.com, and we will consider your request based on applicable law and the technical capabilities of our models.

For information on how to exercise your rights with respect to data we have collected from the internet to train our models, please see this [help center article](#)(opens in a new window).

OpenAI processes your Personal Data for the purposes described in this Privacy Policy on servers located in various jurisdictions, including processing and storing your Personal Data in our facilities and servers in the United States. While data protection law varies by country, we apply the protections described in this policy to your Personal Data regardless of where it is processed, and only transfer that data pursuant to legally valid transfer mechanisms.

6. Children

Our Services are not directed to, or intended for, children under 13. We do not knowingly collect Personal Data from children under 13. If you have reason to believe that a child under 13 has provided Personal Data to OpenAI through the Services, please email us at privacy@openai.com. We will investigate any notification and, if appropriate, delete the Personal Data from our systems. Users under 18 must have permission from their parent or guardian to use our Services.

7. Security

We implement commercially reasonable technical, administrative, and organizational measures designed to protect Personal Data from loss, misuse, and unauthorized access, disclosure, alteration, or destruction. However, no Internet or email transmission is ever fully secure or error free. Therefore, you should take special care in deciding what information you provide to the Services. In addition, we are not responsible for circumvention of any privacy settings or security measures contained on the Service, or third-party websites.

8. Additional U.S. state disclosures

Some U.S. state privacy laws require specific disclosures. The following table provides additional information about the categories of Personal Data we collect and how we use and disclose that information. You can read more about the Personal Data we collect and where we collect it from in “Personal Data we collect” above, how we use Personal Data in “How we use Personal Data” above, and how we retain Personal Data in “Security and Retention” below.

Category of Personal Data

Use of Personal Data

Disclosure of Personal Data

We collect the following information, as described above:

Identifiers, such as your name, contact details, IP address, and other device identifiers

Commercial information, such as your transaction history

Network activity information, such as Content and how you interact with our Services

Communication information, such as your contact information when you send us email

Geolocation data, such as the general area from which your device accesses our Services based on information like its IP address, or precise location information you choose to provide

Your account credentials and payment information

We use this information for the following purposes, as described above:

Provide, analyze, and maintain our Services

Improve and develop our Services and conduct research

Communicate with you, including to send you information about our Services and events

Prevent fraud, illegal activity, or misuses of our Services, and to protect the security of our systems and Services

Comply with legal obligations and protect the rights, privacy, safety, or property of our users, OpenAI, or third parties

We may disclose this information in the following circumstances, as described above:

Vendors, service providers, and affiliates to process in accordance with our instructions

Government authorities or other third parties for the legal reasons described above

Parties involved in Transactions

Business account administrators for the reasons described above

Other users and third parties you interact or share information with

Depending on where you live and subject to applicable exceptions, you may have the following privacy rights in relation to your Personal Data:

The right to know information about our processing of your Personal Data, including the right to access your Personal Data, often in a portable format;

The right to request deletion of your Personal Data;

The right to correct your Personal Data; and

The right to be free from discrimination relating to the exercise of any of your privacy rights.

We don't "sell" Personal Data or "share" Personal Data for cross-contextual behavioral advertising, and we do not process Personal Data for "targeted advertising" purposes (as those terms are defined under state privacy laws). We also don't process sensitive Personal Data for the purposes of inferring characteristics about a consumer.